

Research Practical WS2025

# **TraceSEC: Tracing Security and Privacy in Project Artifacts**

**Phase 3: Requirements Mapping of the VisiOn  
Project to  
ISO/IEC 25010, CRA Annex I, and OWASP ASVS**

**Manani Bhavin Jitendrabhai**

Martikeldnummer: **223201708**

Research Group Software Engineering (RGSE)  
University of Koblenz

Supervisors: Duaa Elsofi, Marco Ehl, Prof. Dr. Jan Jürjens

February 24, 2026

# 1 Introduction

## 1.1 Background

Software development artifacts contain valuable information about security and privacy aspects. TraceSEC focuses on identifying and tracing such information across project artifacts.

## 1.2 Objective

The goal of Phase 3 is:

- Analyze requirements of the VisiOn project
- **Task 1:** Map requirements to ISO/IEC 25010 quality characteristics
- **Task 2:** Map to CRA Annex I requirements (1.3 a–k)
- **Task 3:** Identify relevant OWASP ASVS controls

Table 1: Requirement Analysis for ID 44:

|                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|-------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>[Type:-]<br/>PR/Privacy<br/>Verification</b> | <b>[Description:] "The VisiOn platform shall enable the PA user to notify/inform the citizen if further information is required, in order to verify its privacy requirements."</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Task 1</b>                                   | <p><b>Characteristics:</b><br/> Interaction capability → User assistance (3.4.7)<br/> Interaction capability → Self-descriptiveness (3.4.8)</p> <p><b>Reason:</b><br/> When the system asks the citizen for additional details, it is basically guiding them on what is missing and what they should do next. That fits well with user assistance. At the same time, the message itself should be clear enough so the user immediately understands why the request is happening, which relates to self-descriptiveness.</p> <p><b>Importance:</b><br/> Important because asking for more information is part of completing the privacy verification task properly.</p> |
| <b>Task 2</b>                                   | <p><b>CRA Mapping:</b><br/> (j)</p> <p><b>Reason:</b><br/> This requirement focuses on the communication flow during verification. By notifying users when data is needed, the system fulfils element (j), which requires providing security-related information.</p> <p><b>Importance:</b><br/> It ensures that the verification process is transparent and traceable.</p>                                                                                                                                                                                                                                                                                            |
| <b>Task 3</b>                                   | <p><b>OWASP ASVS:</b><br/> (V14.1.1), (V14.2.4)</p> <p><b>Reason:</b><br/> This ASVS control addresses the identification and documentation of data protection and privacy requirements, which directly correlates to the system's need to verify privacy requirements for citizen information.</p> <p><b>Importance:</b><br/> Ensures that application workflows and notifications do not inadvertently bypass required data protection measures when verifying specific privacy constraints.</p>                                                                                                                                                                     |

Table 2: Requirement Analysis for ID 45:

|                                                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|----------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>[Type:-]</b><br><b>PR/Information</b><br><b>Usage</b> | <b>[Description:] "The VisiOn platform shall analyse the infrastructure of the socio-technical system whenever external actors are involved."</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>Task 1</b>                                            | <p><b>Characteristics:</b><br/>Functional suitability → Functional completeness (3.1.1)<br/>Compatibility → Interoperability (3.3.2)</p> <p><b>Reason:</b><br/>Here the system is expected to consider not just internal components but also external actors, which means the analysis must cover all relevant elements — that's functional completeness. Since external actors are involved, the system also needs to interact with other systems or entities, which naturally relates to interoperability.</p> <p><b>Importance:</b><br/>Important because infrastructure analysis must be included as part of the platform's privacy-related functions.</p> |
| <b>Task 2</b>                                            | <p><b>CRA Mapping:</b><br/>(h)</p> <p><b>Reason:</b><br/>(h) applies because analyzing infrastructure when external actors are involved is a direct way to identify and limit external attack surfaces.</p> <p><b>Importance:</b><br/>External actors are the biggest security variable. Identifying the "hidden" surface area in the hardware and software they use prevents attackers from finding easy ways into the core platform.</p>                                                                                                                                                                                                                     |
| <b>Task 3</b>                                            | <p><b>OWASP ASVS:</b><br/>(V13.1.1), (V13.2.4)</p> <p><b>Reason:</b><br/>This maps strictly to analyzing the infrastructure and defining connections whenever external actors/services interact with the application environment.</p> <p><b>Importance:</b><br/>Documenting all external communications and actors is essential to understanding the full attack surface of the socio-technical system. When external actors are involved without documented controls, unauthorized data flows go unmanaged.</p>                                                                                                                                               |

Table 3: Requirement Analysis for ID 46

| [Type:-]<br>PR/Information<br>Control | [Description:] "The VisiOn platform shall represent/capture obligations as specified by domain experts and derived by applicable law governing the personal information transmission."                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Task 1</b>                         | <p><b>Characteristics:</b><br/>           Functional Suitability → Functional completeness (3.1.1)<br/>           Functional suitability → Functional appropriateness (3.1.3)</p> <p><b>Reason:</b><br/>           The system has to capture every legal rule and actually use them to guide how data is handled properly. If we miss rules or capture them poorly, the whole compliance process breaks down. Finally, we need integrity to lock these obligations down so nobody can tamper with them once they are saved.</p> <p><b>Importance:</b><br/>           Important because legal and expert-defined obligations must be captured accurately.</p> |
| <b>Task 2</b>                         | <p><b>CRA Mapping:</b><br/>           (d), (j)</p> <p><b>Reason:</b><br/>           Legal obligations must remain accurate and protected from any modification, which makes integrity (d) essential. Also, tracking how these obligations are handled or updated supports accountability, aligning with monitoring (j).</p> <p><b>Importance:</b><br/>           IT ensures that all legal and expert-defined obligations related to personal data are correctly captured and represented. If these obligations are incomplete or incorrect, the system may allow actions that violate privacy laws, leading to compliance risks.</p>                        |
| <b>Task 3</b>                         | <p><b>OWASP ASVS:</b><br/>           (V14.1.1)</p> <p><b>Reason:</b><br/>           This requirement is the functional "capture" of legal rules. V14.1.1 specifically mandates that data protection levels must account for privacy regulations and standards.</p> <p><b>Importance:</b><br/>           This is the "brain" of the platform's compliance. It is critical because it takes complex, messy laws and turns them into hard rules for the software, ensuring that every data transfer stays legal without the staff having to guess or memorize the fine print.</p>                                                                               |

Table 4: Requirement Analysis for ID 47

|                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>[Type:-]<br/>PR/Privacy<br/>Verification</b> | <b>[Description:]</b> "The VisiOn platform shall be able to analyse whether the specified information transmission is compliant with the related laws, i.e., information transmission is not conflicting with the laws governing it."                                                                                                                                                                                      |
| <b>Task 1</b>                                   | <b>Characteristics:</b><br>Functional suitability → Functional correctness (3.1.2)<br><b>Reason:</b><br>The platform must analyze and determine a compliance status, aligning directly with the definition: "capability of a product to provide accurate results when used by intended users."<br><b>Importance:</b><br>Important because compliance analysis is only useful if the result is correct.                     |
| <b>Task 2</b>                                   | <b>CRA Mapping:</b><br>(c), (d)<br><b>Reason:</b><br>Analyzing whether transmission is compliant with laws triggers the technical protections in elements (c) and (d). The system must ensure the confidentiality and integrity of data while it is in transit.<br><b>Importance:</b><br>Ensuring confidentiality and integrity guarantees that the system is actually enforcing the law based on the real, original data. |
| <b>Task 3</b>                                   | <b>OWASP ASVS:</b><br>(V14.2.4)<br><b>Reason:</b><br>This verifies that the actual implementation of data transmission and processing complies with the documented privacy controls and legal rules.<br><b>Importance:</b><br>This requirement is a vital safety check to ensure that the data being sent isn't accidentally violating a privacy law, effectively acting as a digital guardrail for every transaction.     |

Table 5: Requirement Analysis for ID 48

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [Type:-]<br>NFR/Usability | [Description:] "The VisiOn platform shall visually notify the PA user if information transmission meets/does not meet the privacy requirements specified by the citizen, and if information transmission meets/does not meet the laws governing the information transmission."                                                                                                                                                                                                                                                                                                                                                                                                        |
| Task 1                    | <p><b>Characteristics:</b><br/> Interaction capability → Self-descriptiveness (3.4.8)<br/> Interaction Capability → Appropriateness Recognizability (3.4.1)</p> <p><b>Reason:</b><br/> The system should clearly tell users what's going on without making them guess. By providing visual alerts that help users quickly figure out if an action is compliant, we're giving them the user assistance they need to do their jobs right. At the same time, keeping these visual cues clear and intuitive naturally improves overall user engagement.</p> <p><b>Importance:</b><br/> Important because the PA user should immediately see whether transmission is compliant or not.</p> |
| Task 2                    | <p><b>CRA Mapping:</b><br/> (j)</p> <p><b>Reason:</b><br/> This satisfies element (j), which requires providing security-related information, Visual notifications and monitoring access to or modification of data.</p> <p><b>Importance:</b><br/> Human operators need to know instantly if a security barrier has been triggered. This "security-related information" allows the PA user to stop an illegal data transfer before it happens.</p>                                                                                                                                                                                                                                   |
| Task 3                    | <p><b>OWASP ASVS:</b><br/> (V16.5.1), (V16.3.2)</p> <p><b>Reason:</b><br/> To notify a user whether a transmission "meets or does not meet" requirements, the system must perform an authorization check. V16.5.1 governs returning messages when policies fail.</p> <p><b>Importance:</b><br/> When the system presents a visual compliance status to a PA user (pass/fail on privacy), it governs that this notification must not leak sensitive internal configuration.</p>                                                                                                                                                                                                        |

Table 6: Requirement Analysis for ID 49

|                                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>[Type:-]<br/>NFR/Usability</b> | <b>[Description:] "The VisiOn platform shall provide the PA users with an integrated interface, through which they can perform all their activities."</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| <b>Task 1</b>                     | <p><b>Characteristics:</b><br/> Interaction capability → Operability (3.4.3)<br/> Interaction capability → Appropriateness recognizability (3.4.1)</p> <p><b>Reason:</b><br/> The goal of an "integrated interface" is to keep everything in one place so it's easy to control. It reduces the effort a PA user has to put in to navigate different modules, making the entire platform easier to operate. Since users might access the system in different environments or contexts, the interface should still work smoothly, which brings in adaptability.</p> <p><b>Importance:</b><br/> Important because one integrated interface makes the platform easier to use in practice.</p> |
| <b>Task 2</b>                     | <p><b>CRA Mapping:</b><br/> <b>(b), (h)</b></p> <p><b>Reason:</b><br/> An integrated interface for PA users acts as a centralized gatekeeper. This helps satisfy <b>(b)</b> by providing a single, manageable control mechanism for access management and <b>(h)</b> by consolidating functions to reduce the total number of attack surfaces.</p> <p><b>Importance:</b><br/> External actors are the biggest security variable. Identifying the "hidden" surface area in the hardware and software they use prevents attackers from finding easy ways into the core platform.</p>                                                                                                        |
| <b>Task 3</b>                     | <p><b>OWASP ASVS:</b><br/> <b>(V8.4.2)</b></p> <p><b>Reason:</b><br/> This requirement provides an interface for PA users. ASVS <b>V8.4.2</b> specifically requires that "access to administrative interfaces incorporates multiple layers of security" and risk analysis.</p> <p><b>Importance:</b><br/> A compromised PA interface could expose all citizen data and system controls at once. <b>V8.4.2</b> ensures the integrated interface is continuously verified, not just protected at login</p>                                                                                                                                                                                  |

Table 7: Requirement Analysis for ID 50

|                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>[Type:-]</b><br><b>NFR/Usability</b> | <b>[Description:]</b> "The VisiOn platform shall provide its citizen users with a web-based interface, through which they can perform all their activities."                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| <b>Task 1</b>                           | <p><b>Characteristics:</b><br/> Interaction capability → Operability (3.4.3)<br/> Flexibility → Adaptability (3.8.1)</p> <p><b>Reason:</b><br/> Just like Req 49, providing a specific web-based interface for user activities aligns directly with the capability to make the system "easy to operate and control". Also, by mandating a "web-based" interface, the requirement ensures the citizen can use the tool regardless of whether they are on a phone, a tablet, or a PC.</p> <p><b>Importance:</b><br/> Important because a web-based interface supports access in different usage environments.</p> |
| <b>Task 2</b>                           | <p><b>CRA Mapping:</b><br/> (h)</p> <p><b>Reason:</b><br/> A web interface is exposed to the internet, which increases risk, so reducing the attack surface (h) is important.</p> <p><b>Importance:</b><br/> It is the most likely target for an attack, so focusing on limiting its surface area is the only way to protect the citizen's sensitive interactions with the government.</p>                                                                                                                                                                                                                      |
| <b>Task 3</b>                           | <p><b>OWASP ASVS:</b><br/> (V3.1.1)</p> <p><b>Reason:</b><br/> Providing a "web-based interface" for citizens triggers V3.1.1, which requires that documentation states the "expected security features that browsers using the application must support."</p> <p><b>Importance:</b><br/> Citizens accessing the platform via browser are the most exposed user group and must be protected by enforced web security baselines. Without HTTPS, HSTS, and CSP, citizen data in transit and in the browser is vulnerable.</p>                                                                                     |

Table 8: Requirement Analysis for ID 51

|                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>[Type:-]</b><br>NFR/Usability | <b>[Description:]</b> "The VisiOn platform shall represent the PLA concerning the citizen information to PA users as a summary of the allowed/forbidden activities to be performed over such information."                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Task 1</b>                    | <p><b>Characteristics:</b><br/>Interaction capability → Self-descriptiveness (3.4.8)</p> <p><b>Reason:</b><br/>Summarizing complex information into allowed/forbidden actions matches the capability to "present appropriate information... to make its capabilities and use immediately obvious to the user without excessive interactions with a product."</p> <p><b>Importance:</b><br/>Important because summarizing the PLA helps users understand the allowed and forbidden actions without reading complex rules.</p>                                                                                                   |
| <b>Task 2</b>                    | <p><b>CRA Mapping:</b><br/>(b), (j)</p> <p><b>Reason:</b><br/>(b) applies because defining allowed and forbidden activities is the foundation of access control mechanisms. (j) applies because the system must monitor user activities against this summary to provide security-related information and ensure forbidden actions aren't taken.</p> <p><b>Importance:</b><br/>This is crucial because it turns a privacy agreement from into actual. Without strict access controls and active monitoring, there's no real way to guarantee citizen data stays safe or to hold anyone accountable if they break the rules.</p> |
| <b>Task 3</b>                    | <p><b>OWASP ASVS:</b><br/>(V8.1.1)</p> <p><b>Reason:</b><br/>A PLA summarising allowed and forbidden activities over citizen information is, in ASVS terms, an authorization policy defining function-level and data-specific access rules.</p> <p><b>Importance:</b><br/>Without documented function-level and data-specific access rules, the PLA has no technical enforcement. <b>V8.1.1</b> ensures the PLA translates directly into verifiable, implementable access controls.</p>                                                                                                                                        |